

HIPAA and Data Security Policy

Daisy Health

Policy ID: HR-DS-003

Effective Date: January 1, 2025

Last Reviewed: June 1, 2025

Owner: Compliance and Information Security

Purpose

Daisy Health handles protected health information (PHI) and sensitive personal data every day. This policy outlines how all employees must handle, protect, and report on that data. Compliance is not optional — violations can result in federal penalties, patient harm, and termination.

Scope

This policy applies to all Daisy Health employees, contractors, and vendors who access Daisy Health systems or patient data. Clinical and non-clinical staff alike are covered.

1. HIPAA Basics

The Health Insurance Portability and Accountability Act (HIPAA) sets federal standards for protecting patient health information. As a virtual primary care company, Daisy Health is a covered entity under HIPAA.

What Is PHI?

Protected Health Information (PHI) includes any information that can identify a patient and relates to their health condition, care, or payment. Examples include:

- Patient name combined with a diagnosis
- Medical record numbers
- Appointment dates and clinical notes
- Insurance information
- Any demographic data linked to health information

Minimum Necessary Standard

Employees must access only the PHI they need to do their job. Do not look up patient records out of curiosity, even for patients you know personally.

2. Required HIPAA Training

All employees must complete HIPAA training:

- **New hire training:** Within 7 days of start date, through the Daisy Health Learning Management System (LMS)
- **Annual refresher:** Every 12 months, required for all staff
- **Role-specific training:** Clinical staff complete additional training on documentation standards and telehealth privacy requirements
- **Completion is tracked** — managers are notified if direct reports are overdue

Failure to complete required training on time may result in suspension of system access until training is complete.

3. Device and Endpoint Security

Company-Issued Devices

All employees handling PHI must use a **Daisy Health-issued device**. Company devices come pre-configured with:

- Full disk encryption
- Endpoint detection and response (EDR) software
- Automatic screen lock after 5 minutes of inactivity
- Remote wipe capability

Personal Devices (BYOD)

Personal devices may only be used for work with explicit IT approval and must be enrolled in Daisy Health's Mobile Device Management (MDM) system. Personal devices may never be used to access, store, or transmit PHI without MDM enrollment.

Screen Lock

Lock your screen whenever you step away from your device. On Mac: Command + Control + Q. On PC: Windows + L.

4. Network and VPN Requirements

Employees must connect through the **Daisy Health VPN** whenever accessing:

- The electronic health record (EHR) system
- Patient records or case management tools
- Internal HR systems containing employee PII
- Any internal Daisy Health application

Public Wi-Fi (coffee shops, airports, hotels) must never be used without VPN active. If VPN is unavailable, stop work and reconnect before proceeding.

5. Password and Access Management

- Passwords must be at least **14 characters** and include uppercase, lowercase, numbers, and symbols
 - Do not reuse passwords across work and personal accounts
 - Use the company-provided **password manager** for all work credentials
 - **Multi-factor authentication (MFA)** is required for all Daisy Health systems — no exceptions
 - Do not share your login credentials with anyone, including colleagues or IT support staff
 - If you believe your credentials have been compromised, notify IT Security immediately at security@daisyhealth.com
-

6. Email and Communication Security

- PHI must never be sent via **personal email** (Gmail, Yahoo, etc.)
 - PHI sent via Daisy Health email must be **encrypted** — use the [Encrypt] button in Outlook before sending
 - Do not send PHI via SMS or personal messaging apps
 - Patient-facing communications must only occur through the **Daisy Health secure messaging platform**
 - Be alert to **phishing emails** — do not click unknown links or attachments. Report suspicious emails to security@daisyhealth.com
-

7. Remote Work and Privacy Requirements

When working remotely, employees must:

- Ensure their workspace is **private** — no patient conversations where others can overhear

- Use a **privacy screen filter** if working in a semi-public location (not recommended for clinical staff)
- Never leave patient information visible on screen in shared living spaces
- Use **headphones** for all telehealth encounters to prevent audio from being overheard

Clinical staff conducting patient visits must ensure their background is professional and their environment is HIPAA-compliant. Patients must not see or hear other household members during clinical encounters.

8. Data Storage and Handling

- Patient data must only be stored in **Daisy Health-approved systems** — never in personal cloud storage (Google Drive personal, Dropbox, iCloud)
 - Do not download patient data to local device storage unless absolutely necessary and approved by IT
 - Hard copies of PHI must be stored in locked containers and shredded when no longer needed — use designated secure shredding bins
 - Do not take screenshots of patient records unless required for a clinical or technical workflow, and store them only in approved systems
-

9. Incident Reporting

If you suspect a data breach, privacy violation, or security incident, you must report it **immediately** — do not wait.

What to Report

- Lost or stolen device
- Accidental disclosure of PHI (sent to wrong person, left visible, etc.)
- Suspected unauthorized access to patient or employee records
- Phishing attack or malware infection
- Any situation where you are unsure if PHI was exposed

How to Report

- **Email:** security@daisyhealth.com
- **Phone:** IT Security Hotline at 1-800-DAISY-SEC (available 24/7)
- **Your manager** — notify them simultaneously

HIPAA requires Daisy Health to investigate and, if applicable, notify affected patients within **60 days** of discovering a breach. Prompt reporting is critical.

No Retaliation

Employees who report incidents in good faith will not face retaliation, even if the incident resulted from their own mistake. Daisy Health encourages a culture of transparency around security events.

10. Consequences of Violations

HIPAA violations are taken seriously at Daisy Health and carry both organizational and personal consequences.

Violation Type	Potential Consequence
Accidental, promptly reported	Retraining, documented warning
Negligent (avoidable, unreported)	Suspension, termination
Willful — no harm	Up to \$10,000 federal fine per violation
Willful — harm caused	Up to \$250,000 federal fine; criminal charges possible

Daisy Health will cooperate fully with any regulatory investigation and will not shield employees who willfully violate HIPAA.

Related Policies

- HR-RW-001: Remote Work Policy
 - HR-LC-004: Licensure and Credentialing Policy
 - HR-ET-008: Equipment and Technology Policy
-

Sample Employee Questions This Document Answers

- What counts as PHI and how should I handle it?
- Can I use my personal laptop for work if I do not have my work laptop?
- What do I do if I accidentally send patient information to the wrong person?
- Do I need to use VPN when working from home?
- When is my HIPAA training due?
- Can I take notes about a patient on my personal phone?